ONE-PAGE BRIEF

Post-quantum cryptography review: zebra @ 147a6a8bf7d3

Client: Zcash Foundation — public repository (passive review) · Source: github.com/ZcashFoundation/zebra, commit `147a6a8bf7d3` · Reviewed: 2026-10-28 13:04 UTC · Risk profile: Small technology company

POST-QUANTUM MATURITY

Level 0 of 4

no post-quantum cryptography

FINDINGS

0 Critical **2** High **2** Medium

9 Low **6** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)

Key establishment: 5 + 3 − 12 = -4 → **time available**

Signatures: 5 + 3 − 12 = -4 → **time available**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

High QSI-2026-05258	**quinn-proto 0.11.16 is affected by RUSTSEC-2026-0340** What to do: Upgrade to a fixed version (0.11.18).
High QSI-2026-05259	**quinn-proto 0.11.16 is affected by RUSTSEC-2026-0341** What to do: Upgrade to a fixed version (0.11.17).
Medium QSI-2026-05254	**opentelemetry_sdk 0.31.0 is affected by GHSA-w9wp-h8wv-79jx (CVE-2026-48504)** What to do: Upgrade to a fixed version (0.32.1).
Medium QSI-2026-05252	**block-buffer 0.10.4 is affected by GHSA-qwgh-2vcv-g2f7** What to do: Upgrade to a fixed version (none published yet; see the advisory for mitigations).

9 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Low transaction and message signing	Ed25519	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum...
Low role not determined	X25519, BLS12-381, ECDSA	Classify each usage, record data lifetimes, and plan migration to Hybrid key establishment with ML-KEM (FIPS...

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 9; unlikely to apply to this build: 1 (a Cargo feature that is off, affected functions not named in the code, or a platform that is not built); to review: 8.

Analyst review: 0 confirmed, 0 not applicable, 1 dismissed as false positives. (QSI review, 2026-10-23)

Static review of source code and manifests; files analysed: 439. No requests were sent to the owner's systems.

Full report, content SHA-256: `ee7b94a59f12e7f13dc01adc6ec7e927c84e349194b3f02b357fd6092000614f`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.